

Reporte niveles de Bandit

Título: Bandit Level 16 - 17

Objetivo del nivel: Encontrar la siguiente contraseña enviando la actual en un rango de puertos del **31000 to 32000** encontrando cual de ellos acepta transferencia ssl/tls

Herramientas utilizadas: ssh, telnet, nc, openssl, s_client, nmap

Pasos realizados:

Generar un script para encontrar los puertos disponibles que escuchan SSL/TLS

Pegarlos directamente en la terminal de la sesión de bandit16

Evidencia de realización:

```
#!/bin/bash
```

```
PASS_FILE="/etc/bandit_pass/$(whoami)"
```

```
if [ ! -r "$PASS_FILE" ]; then
```

```
    echo "No puedo leer $PASS_FILE. Ejecuta esto como el usuario del nivel actual."
```

```
    exit 1
```

```
fi
```

```
PASS="$(cat $PASS_FILE)"
```

```
echo "Usando contraseña desde: $PASS_FILE"
```

```
echo
```

```
# archivos temporales
```

```
TMPDIR=$(mktemp -d)
```

```
trap "rm -rf $TMPDIR" EXIT
```

```
echo "Escaneando puertos 31000..32000 (esto puede tomar ~20-40s)..."
```

```
open_ports=()
```

Seguridad en Entornos de Desarrollo

Estudiante: Abraham Alejandro Flores Vásquez

```
for p in {31000..32000}; do
```

```
    # primero intenta nc -z (si nc existe)
```

```
    if command -v nc >/dev/null 2>&1; then
```

```
        timeout 1 nc -z -w 1 localhost $p 2>/dev/null
```

```
        if [ $? -eq 0 ]; then
```

```
            echo "ABIERTO (nc) $p"
```

```
            open_ports+=( "$p" )
```

```
            continue
```

```
        fi
```

```
    fi
```

```
    # /dev/tcp fallback
```

```
    timeout 1 bash -c "echo > /dev/tcp/localhost/$p" 2>/dev/null
```

```
    if [ $? -eq 0 ]; then
```

```
        echo "ABIERTO (devtcp) $p"
```

```
        open_ports+=( "$p" )
```

```
        continue
```

```
    fi
```

```
    # intento TLS rápido (por si solo responde con TLS y nc -z falla)
```

```
    if command -v openssl >/dev/null 2>&1; then
```

```
        timeout 1 bash -c "echo | openssl s_client -connect localhost:$p >/dev/null 2>&1"
```

```
        if [ $? -eq 0 ]; then
```

```
            echo "POSIBLE-TLS $p"
```

```
            open_ports+=( "$p" )
```

```
            continue
```

Seguridad en Entornos de Desarrollo
Estudiante: Abraham Alejandro Flores Vásquez

```
fi

fi

done


if [ ${#open_ports[@]} -eq 0 ]; then

    echo

    echo "No encontré puertos abiertos en 31000..32000 con estos timeouts."

    echo "Prueba aumentar timeouts (reemplaza timeout 1 por timeout 2 o 3) y vuelve a intentar."

    exit 0

fi


echo

echo "Probando cada puerto encontrado (${#open_ports[@]}) enviando la contraseña y buscando respuesta distinta..."

for p in "${open_ports[@]"; do

    echo "--- puerto $p ---"

    # detectar TLS por inspección breve

    is_tls=0

    if command -v openssl >/dev/null 2>&1; then

        timeout 1 bash -c "echo | openssl s_client -connect localhost:$p 2>$TMPDIR/openssl_$p.out >/dev/null"

        # si el archivo contiene SSL-Session o BEGIN CERTIFICATE lo marcamos TLS

        if grep -qE "SSL-Session|BEGIN CERTIFICATE|Cipher is" "$TMPDIR/openssl_$p.out" 2>/dev/null; then

            is_tls=1

        fi

    fi

done
```

Seguridad en Entornos de Desarrollo
Estudiante: Abraham Alejandro Flores Vásquez

```
fi

if [ $is_tls -eq 1 ]; then

    echo " -> detected TLS. Enviando via openssl..."

    # enviar password vía TLS y guardar respuesta

    printf "%s\n" "$PASS" | timeout 3 openssl s_client -connect localhost:$p -quiet -
ign_eof 2>/dev/null > "$TMPDIR/resp_$p.txt" || true

else

    echo " -> no-TLS detectado. Enviando via nc (o /dev/tcp si nc no existe)..."

    if command -v nc >/dev/null 2>&1; then

        printf "%s\n" "$PASS" | timeout 3 nc -w 2 localhost $p > "$TMPDIR/resp_$p.txt"
2>/dev/null || true

    else

        printf "%s\n" "$PASS" | timeout 3 bash -c "cat > /dev/tcp/localhost/$p" >
"$TMPDIR/resp_$p.txt" 2>/dev/null || true

    fi

fi

# limpiar salida (borrar líneas vacías)

resp="$(sed '/^[:space:]*$/d' "$TMPDIR/resp_$p.txt" 2>/dev/null || true)"

if [ -z "$resp" ]; then

    echo " -> sin respuesta (o respuesta vacía)."

    continue

fi

# si la respuesta no es exactamente la contraseña enviada, la reportamos

# comparamos sin saltos finales
```

Seguridad en Entornos de Desarrollo

Estudiante: Abraham Alejandro Flores Vásquez

```
pass_trim="$(echo -n "$PASS" | tr -d '\r\n')"
```

```
resp_trim="$(echo -n "$resp" | tr -d '\r\n')"
```

```
if [ "$resp_trim" != "$pass_trim" ]; then
```

```
    echo
```

```
    echo "¡¡Respuesta distinta recibida en puerto $p!!"
```

```
    echo "---- inicio respuesta (puerto $p) ----"
```

```
    cat "$TMPDIR/resp_$p.txt"
```

```
    echo "---- fin respuesta ----"
```

```
    echo
```

```
    echo "Si eso es la contraseña, úsala para conectarte al siguiente nivel."
```

```
    exit 0
```

```
else
```

```
    echo " -> eco (me devolvió la misma contraseña)."
```

```
fi
```

```
done
```

```
echo
```

```
echo "He probado todos los puertos abiertos detectados. No encontré una respuesta distinta."
```

```
echo "Si nada aparece, intenta aumentar timeouts (reemplaza timeout 1/3 por 2/5) y re-ejecuta."
```

```
exit 0
```

Seguridad en Entornos de Desarrollo
Estudiante: Abraham Alejandro Flores Vásquez

```
# primero intenta nc -z (si nc existe)
if command -v nc >/dev/null 2>&1; then
  timeout 1 nc -z -w 1 localhost $p 2>/dev/null
  if [ $? -eq 0 ]; then
    echo "ABIERTO (nc) $p"
    echo ";;Respuesta distinta reci ]; thenn')"seña enviada, la reportamose)" >
Usando contraseña desde: /etc/bandit_pass/bandit16

Escaneando puertos 31000..32000 (esto puede tomar ~20-40s)...
ABIERTO (nc) 31046
ABIERTO (nc) 31518
ABIERTO (nc) 31691
ABIERTO (nc) 31790
ABIERTO (nc) 31960

Probando cada puerto encontrado (5) enviando la contraseña y buscando respuesta
distinta...
> kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
> kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
> kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
> kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
> kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
```

Probando cada uno, solo uno devuelve una key: Correct!

-----BEGIN RSA PRIVATE KEY-----

MIIEogIBAAKCAQEAvmOkuifmMg6HL2YPIOjon6iWfbp7c3jx34YkYWqUH57SUdyJ
imZzeyGC0gtZPGujUSxiJSWI/oTqexh+cAMTSMIOJf7+BrJOObArnxd9Y7YT2bRPQ
Ja6Lzb558YW3FZl87ORiO+rW4LCDCNd2IUvLE/GL2GWyuKN0K5iCd5TbtJzEkQTu
DSt2mcNn4rhAL+JFr56o4T6z8WWAW18BR6yGrMq7Q/kALHYW3OekePQAzL0VUYbW
JGTi65CxbCnzc/w4+mqQyvmzpWtMAzJTzAzQxNbkR2MBGySxDLrjg0LWN6sK7wNX
x0YVztz/zblkPjfkU1jHS+9EbVNj+D1XFOJuaQIDAQABAolBABagpxpM1aoLWfvD
KHcj10nqcoBc4oE11aFYQwik7xfW+24pRNUDE6SFthOar69jp5RLLwD1NhPx3iBl
J9nOM8OJOVToum43UOS8YxF8WwhXriYGnc1sskbwpXOUDc9uX4+UESzH22P29ovd
d8WErY0gPxun8pbJLmxkAtWNhpMvfe0050vk9TL5wqbu9AlbssgTcCXkMQnPw9nC
YNN6DDP2lbcBrvgT9YCNL6C+ZKufD52yOQ9qOkwFTEQpjtF4uNtUom+asvlpmS8A
vLY9r60wYSvmZhNqBUrj7lyCtXmIu1kkd4w7F77k+DjHoAXyxcUp1DGL51sOmama
+TOWWgECgYEA8JtPxP0GRJ+IQkX262jM3dElkza8ky5molwUqYdsx0NxHgRRhORT
8c8hAuRBb2G82so8vUHK/fur85OEfc9TncnCY2crpoqsgghifKLxrLgtT+qDpfZnx
SatLdt8GfQ85yA7hnWWJ2MxF3NaeSDm75Lsm+tBbAiyC9P2jGRNtMSkCgYEAypHd

Seguridad en Entornos de Desarrollo

Estudiante: Abraham Alejandro Flores Vásquez

HCctNi/FwjulhttFx/rHYKhLidZDFYeiE/v45bN4yFm8x7R/b0iE7KaszX+Exdvt

SghaTdcG0Knyw1bpJVyusavPzpaJMjdJ6tcFhVAbAjm7enClvGCSx+X3l5SiWg0A

R57hJglezliVjv3aGwHwvlZvtszK6zV6oXFAu0ECgYAbjo46T4hyP5tji93V5HDI

TtieK7xRVxUl+iU7rWkGAXFpMLFteQEsRr7PJ/lemmEY5eTDAFmLy9FL2m9oQWCg

R8VdwSk8r9FGLS+9aKcV5PI/WEKlwGxinB3OhYimtiG2Cg5JCqIZFHxD6MjEGOiU

L8ktHMPvodBwNsSBULpG0QKBgBAplTfC1HOnWiMGOU3KPwYWt0O6CdTkmJOmL8
Ni

blh9elyZ9FsGxsgtRBXRsqXuz7wtsQAgLHxbdLq/ZJQ7YfzOKU4ZxEnabvXnvWkU

YOdjHdSOoKvDQNWu6ucyLRAWFuLSeXw9a/9p7ftpxm0TSgyvmfLF2MIAEwyzRqaM

77pBAoGAMmjmlJdjp+Ez8duyn3ieo36yrttF5NSsJLAbxFpdlc1gvtGCWW+9Cq0b

dxviW8+TFVEBl1O4f7HVm6EpTscdDxU+bCXWkfjuRb7Dy9GOtt9JPsx8MBTakzh3

vBgysi/sN3RqRBcGU40fOoZyfAMT8s1m/uYv52O6lgeuZ/ujbjY=

-----END RSA PRIVATE KEY-----

Explicación de por que funciona la solución: El script facilita el proceso de escucha de los puertos, los disponibles son probados con tecnología ssl/ tlc o ssh.

Password o resultado obtenido: key

Dificultados o retos encontrados: Generar el script

Aprendizaje/reflexiones: Se pueden investigar que puertos están listos para escuchar cierta información y comprobarlos uno por uno para poder explotar y pedir información a través de ellos.